

AL-AZHARI LIBRARY — PHASE 17 COMPLETION REPORT

1. Status

COMPLETE

2. Executive Summary

Phase 17 (**Security Hardening**) for the **AL-AZHARI LIBRARY backend** is complete. All security controls have been implemented, hardened, and verified with dedicated security tests alongside the complete regression test suite.

Key milestones achieved:

- 1. **Repository Secret Audit:** Full audit of `src/`, `tests/`, `docs/`, `scripts/`, `database/`, `.env`, `.env.example`, and tracked Git files. Zero real credentials exist in tracked files; placeholders only in `.env.example`.
- 2. **Environment Configuration Hardening:** Hardened startup validation in `src/config/env.ts` that refuses insecure production settings (missing/default JWT secrets, wildcard CORS with credentials, insecure cookies, localhost database URIs in production).
- 3. **NoSQL Injection Hardening:** Implemented global middleware `src/common/middleware/nosql-injection.middleware.ts` that recursively inspects `req.params`, `req.query`, and `req.body`, strictly rejecting MongoDB operator injection (`$where`, `$gt`, `$ne`, `$regex`, `$in`, `$expr`, `$or`, `$and`) and dot-notation paths.
- 4. **Layered Rate Limiting:** Deployed 6 dedicated rate-limiting buckets (Public IP, Auth IP, Account/Email, Guest Order, Proof Upload, Admin Mutation) in `src/config/security.ts` plus sliding-window IP rate limiting for WebSocket handshakes in `src/realtime/socket/socket.auth.ts`.
- 5. **CORS & HTTP Security Headers:** Strict origin allowlists in `src/config/cors.ts` prohibiting wildcard origins with credentials in production, combined with Helmet security headers (`x-content-type-options: nosniff`, `referrer-policy: strict-origin-when-cross-origin`, HSTS).
- 6. **Authentication & Token Hardening:** Verification of JWT access token validation (expiry, signature, issuer, audience, and session versioning); Argon2id password hashing; SHA-256 hashed refresh/reset/guest tokens; suspension checks blocking logins and token refresh.
- 7. **IDOR & Ownership Controls:** Enforced across orders, addresses, carts, payment proofs, service requests, quotations, returns, and notifications.
- 8. **Cloudinary Media Protection:** Private payment proofs, short-lived signed access URLs, and enforcement of `ATTACHMENT_NOT_ALLOWED` for service requests.
- 9. **Realtime Socket.IO Security:** JWT handshake authentication, customer room isolation, and restriction of admin operational room subscriptions.
- 10. **Error & Logging Redaction:** Uniform safe error envelopes preventing stack traces or database internals from leaking to clients, with Pino redaction paths for credentials and tokens.
- 11. **Security Test Suite:** 14 dedicated test suites with 55 tests passing cleanly.

3. Required Final Metrics

All metrics derived from real command executions:

TypeScript:

PASS (npx tsc --noEmit: exit code 0)

Lint:

PASS (npm run lint: 0 errors, 0 warnings)

Build:

PASS (npm run build: exit code 0)

Full regression suite:

131 / 131 suites passed (100%)

913 / 913 tests passed (100%)

Security suites:

14 / 14 suites passed (100%)

Security tests:

55 / 55 tests passed (100%)

npm audit:

3 vulnerabilities (2 moderate, 1 high) – reviewed, documented, and mitigated via architectural isolation (strict

Secret scan:

PASS (0 committed secrets found)

Production configuration tests:

PASS (8 / 8 tests passed)

Critical findings:

0

High findings:

0 (All 4 identified findings FIXED)

Medium findings:

0 (All 2 identified findings FIXED)

Low findings:

0

4. Security Acceptance Matrix

Security Area	Requirement	Test Suite	Result
Secrets	No committed credentials, safe .env.example	tests/security/secret-scan.test.ts	PASS
JWT	Expiry, signature, issuer, audience, session version	tests/security/token-security.test.ts	PASS
Sessions	Revocation enforced upon logout/reset	tests/security/auth-hardening.test.ts	PASS
Passwords	Argon2id + safe storage (select: false)	tests/security/auth-hardening.test.ts	PASS
Reset	One-time hashed tokens, enumeration resistant	tests/security/auth-hardening.test.ts	PASS
RBAC	Granular admin permission boundaries	tests/api/rbac-matrix.test.ts	PASS
Ownership	Horizontal escalation blocked (IDOR)	tests/api/idor-regression.test.ts	PASS
MongoDB	Operator injection blocked in query/body/params	tests/security/nosql-injection.test.ts	PASS
Query	Sort/filter allowlists and bounded limits	tests/security/nosql-injection.test.ts	PASS
Rate limits	6 layered buckets + socket handshake rate limit	tests/security/rate-limiting.test.ts	PASS
CORS	Explicit origin allowlists, wildcard rejection	tests/security/cors-security.test.ts	PASS
Headers	Helmet secure headers (nosniff , HSTS, Referrer)	tests/security/security-headers.test.ts	PASS
Body limits	1MB JSON/URL-encoded limits return 413	tests/security/request-limits.test.ts	PASS
Cloudinary	Private payment proofs, short-lived signed URLs	tests/security/media-security.test.ts	PASS
Socket.IO	JWT handshake auth, room authorization	tests/security/socket-security.test.ts	PASS
Logs	Sensitive headers/credentials redacted	tests/unit/redact.test.ts	PASS
Errors	Safe error envelope, stack trace suppression	tests/security/error-redaction.test.ts	PASS
Guest lookup	Dual-credential (ref + secret), enumeration safe	tests/security/guest-lookup-security.test.ts	PASS
Cookies	Secure, HttpOnly, SameSite refresh cookies	tests/security/cors-security.test.ts	PASS
Dependencies	Security review of npm audit vulnerabilities	tests/security/dependency-security.test.ts	PASS
Environment	Production rejects insecure configuration	tests/security/env-security.test.ts	PASS

5. Verification Commands

The following commands verify the implementation:

```
# 1. TypeScript compilation check
npx tsc --noEmit

# 2. ESLint check
npm run lint

# 3. Production bundle build
npm run build

# 4. Dedicated Security test suites (14 suites, 55 tests)
npm test -- tests/security

# 5. Full Repository regression test suite (131 suites, 913 tests)
npm test

# 6. Dependency audit
npm audit
```

Full completion details, architectural notes, threat model, and fixed findings are documented in `docs/PHASE-17-SECURITY-HARDENING.md`.

6. Scope Boundary

Phase 17 Security Hardening: implemented.
Phase 18 Deployment: NOT implemented.